

Concept	SQL (Drizzle/MySQL)	MongoDB (Mongoose)
Type safety	End-to-end via tRPC	Manual TypeScript interfaces

24. Removed Features (Historical)

The following fields/collections were previously part of the schema but have been removed:

Removed Item	Reason
zones collection	Replaced by <code>DynamicZone</code>
zoneRules collection	Replaced by <code>DynamicZoneRule</code>
<code>Person.isTeamLead</code> field	No longer needed; leads managed via <code>ZoneAssignment</code>
<code>Person.location</code> field	Replaced by <code>city</code> field
<code>Person.ageGroup</code> field	Replaced by <code>ageRange</code> field
<code>Person.wantsToPlay</code> field	Merged into <code>acoNeeded</code> (Yes/No)

25. GDPR Compliance & Security

25.1 PDF Export — Role-Based Access Control

The PDF export route (`GET /api/export/assignments-pdf`) enforces role-based scoping:

Role	Access
Admin	Full export — all assignments across all zones
Zone Lead	Filtered to assignments in their assigned zones only
Area Lead	Filtered to assignments in their assigned zones only
Hotel Person	Blocked — returns HTTP 403 Forbidden
Regular User	Blocked — returns HTTP 403 Forbidden

```

router.get("/assignments-pdf", requireAuth, async (req, res) => {
  const user = req.user;
  let assignments = await getAllAssignments();

  if (user.role === "zone_lead") {
    const zones = await ZoneAssignment.find({ userId: user._id
    }).distinct("zone");
    assignments = assignments.filter(a => zones.includes(a.zone));
  } else if (user.role === "area_lead") {
    const areas = await AreaAssignment.find({ userId: user._id });
    const zones = [...new Set(areas.map(a => a.zone))];
    assignments = assignments.filter(a => zones.includes(a.zone));
  } else if (user.role === "user" || user.role === "hotel_person") {
    return res.status(403).json({ error: "Forbidden" });
  }

  // ... generate PDF with scoped assignments ...
});

```

25.2 Bulk Operations — Admin-Only Authorization

The following destructive bulk operations require `requireAdmin` middleware:

Endpoint	Protection
POST /api/people/bulk-delete	requireAdmin
PATCH /api/people/bulk-toggle-aco	requireAdmin
PATCH /api/people/bulk-check-in	requireAdmin

Previously these were accessible to any authenticated user. They now enforce admin-only access.

25.3 LLM Data Minimization

The Search Assistant sends only the minimum necessary fields to the external LLM:

Sent to LLM	NOT Sent to LLM
name	city
zone	state
area	country
acoNeeded	gender
team	ageRange
hotel	memberId
roomNumber	mandal
	email
	phone
	familyId

25.4 Rate Limiting

Limiter	Scope	Limit
General	/api/*	100 requests/min
Auth	/api/auth/*	10 requests/min
Write	Mutations	30 requests/min
Bulk	Bulk operations	5 requests/min
Export	PDF export	3 requests/min

25.5 Hotel Person Data Isolation

Hotel persons are scoped to only their assigned hotels:

- The `tournaments.list` endpoint filters results to only assigned hotels for `hotel_person` users.
 - Room management operations validate that the `hotel_person` has access to the target hotel.
 - Hotel persons cannot access People, Teams, Assignments, or Admin pages.
-

26. Admin Panel — Hotel Persons Tab

The Admin Panel includes a “Hotel Persons” tab for managing hotel person accounts:

Features:

- Generate credentials (username/password) for hotel persons.
- Assign one or more hotels to each hotel person.
- Remove hotel assignments from hotel persons.
- Regenerate passwords for existing hotel persons.
- Delete hotel person credentials.
- View list of all hotel persons with their assigned hotels.

Workflow:

1. Admin navigates to Admin Panel → Hotel Persons tab.
 2. Admin clicks “Generate Credentials” with a username.
 3. System creates a user with `role: "hotel_person"` and hashed password.
 4. Admin assigns hotels to the hotel person from the available hotels list.
 5. Hotel person can now log in and manage rooms for their assigned hotels only.
-

End of MERN specification.